

VindobonaPay GmbH — DORA Compliance Mapping

Regulation (EU) 2022/2554 | Full regime (Art. 5–15) — authorised payment institution, not a microenterprise | Competent authority: FMA (Austria) | Version 1.0 | Fictional company for educational purposes

#	Article	Requirement	Status	Supporting evidence (ISMS)	Gap	Action	Owner	Target
Pillar 1 — ICT risk management (Chapter II, Art. 5–16)								
DR-01	Art. 5	Management body defines, approves and oversees the ICT risk management framework, and keeps its ICT knowledge up to date.	Partial	A.5.4 management responsibilities; InfoSec Policy approved by management; management review meetings.	The framework is approved, but there is no structured ICT training for the management body and no record of it.	Deliver a yearly ICT risk briefing to the management body and keep attendance records.	CISO	Q4 2026
DR-02	Art. 6	Sound, documented ICT risk management framework, reviewed at least yearly, with a digital operational resilience strategy.	Partial	ISMS documentation; risk assessment methodology; Risk Register (Deliverable 02); SoA (Deliverable 01).	The ISMS covers the substance, but it is not yet presented as a DORA ICT risk framework with a documented resilience strategy.	Document the ICT risk management framework and the digital operational resilience strategy in DORA terms.	CISO	Q1 2027
DR-03	Art. 6(6)	The ICT risk framework is subject to internal audit by auditors with ICT expertise (non-microenterprises).	Gap	A.5.35 independent review is planned; no internal audit performed yet.	No internal audit of the ICT risk framework has been carried out.	Schedule the first internal audit of the ICT risk framework with an auditor with ICT expertise.	Management	Q1 2027
DR-04	Art. 6(4)	Responsibility for managing ICT risk is assigned to a control function with appropriate independence.	Compliant	CISO role established in 2025, reporting to the CEO; roles and responsibilities documented (A.5.2).	No gap: the CISO function is separate from IT operations and reports to the CEO.	Maintain independence as the team grows; document the reporting line in the framework.	CEO	Ongoing
DR-05	Art. 7	ICT systems, protocols and tools are reliable, technologically resilient and appropriate to the scale of operations.	Compliant	Azure platform with availability zones (A.8.14); capacity monitoring (A.8.6); Intune-managed endpoints (A.8.1).	No gap: infrastructure is proportionate to the size and criticality of the service.	Review capacity and architecture yearly against business growth.	CTO	Ongoing
DR-06	Art. 8	Identification of ICT-supported business functions, information assets and dependencies, including on ICT third parties.	Partial	Asset inventory (A.5.9); risk assessment with asset-based approach; supplier list (partial).	Assets are inventoried, but critical or important functions are not formally identified and mapped to supporting assets and providers.	Identify critical or important functions and map them to assets and ICT providers.	CTO	Q4 2026
DR-07	Art. 9	Protection and prevention: security policies, identity and access management, encryption, network security, change management.	Compliant	A.8.5 MFA and Conditional Access; A.8.3 RBAC; A.8.24 encryption; A.8.20–A.8.22 network security; A.8.32 change management.	No gap at framework level. Individual weaknesses (privileged MFA enrollment, cloud baselines) are tracked in the SoA and Risk Register.	Close the open remediation actions already tracked in Deliverables 01 and 02.	IT Manager	Q4 2026
DR-08	Art. 10	Detection: mechanisms to promptly detect anomalous activities, with defined alert thresholds and criteria.	Partial	A.8.15 logging (partially centralized); A.8.16 monitoring; Defender for Endpoint alerts.	Log collection does not yet cover all payment platform components and alerting use cases are not fully defined.	Extend log coverage to all payment components and document alerting use cases and thresholds.	CISO	Q4 2026
DR-09	Art. 11	ICT business continuity policy, response and recovery plans, tested periodically.	Partial	A.5.29, A.5.30; BCP in draft; RTO/RPO defined; Incident Response Plan v1.1.	The Business Continuity Plan is still in draft and no ICT continuity test has been performed.	Approve the BCP and run the first ICT continuity test.	COO	Q4 2026
DR-10	Art. 12	Backup policies and procedures, restoration and recovery methods, with redundant capacity where required.	Compliant	A.8.13 Azure Backup with periodic restore tests; A.8.14 redundancy across availability zones.	No gap: backups are automated and restore tests are documented.	Keep restore test records as evidence for supervisory review.	IT Manager	Ongoing
DR-11	Art. 13	Learning and evolving: post-incident reviews, ICT awareness programmes and training for staff.	Partial	A.5.27 post-incident reviews (informal); A.6.3 yearly awareness training and phishing simulations.	Staff training is in place; post-incident reviews are not yet formalized into a documented lessons-learned process.	Introduce a formal lessons-learned template feeding the ISMS improvement cycle.	CISO	Q3 2026
DR-12	Art. 14	Crisis communication plans for responsible disclosure of major incidents to clients, counterparts and the public.	Gap	Incident Response Plan covers internal communication only.	No crisis communication plan for external disclosure to clients, counterparts or the public.	Define a crisis communication plan with roles, templates and approval path.	COO	Q1 2027
Pillar 2 — ICT-related incident management, classification and reporting (Chapter III, Art. 17–23)								
DR-13	Art. 17	ICT-related incident management process to detect, manage and notify incidents, with defined roles and procedures.	Compliant	A.5.24–A.5.26; Incident Response Plan v1.1 with triage criteria and runbooks.	No gap: the internal incident process is documented and operational.	Align the plan wording with DORA terminology at the next review.	CISO	Q4 2026
DR-14	Art. 18	Classification of ICT-related incidents against the criteria set by the regulation and its technical standards.	Gap	A.5.25 internal triage criteria defined by the organization.	Incidents are triaged internally but not classified against the regulatory criteria that determine whether an incident is major.	Add a regulatory classification step to the Incident Response Plan, based on the applicable technical standards.	Compliance Officer	Q1 2027
DR-15	Art. 19	Reporting of major ICT-related incidents to the competent authority: initial notification, intermediate report and final report.	Gap	A.5.5 authority contact list (FMA, CERT.at); A.5.31 legal and regulatory register.	No documented reporting workflow: deadlines, templates, responsibilities and escalation path are not defined.	Define the regulatory reporting procedure for the FMA, with deadlines and named responsibilities.	Compliance Officer	Q1 2027
DR-16	Art. 23	Operational or security payment-related incidents are reported under the same regime (relevant for payment institutions).	Gap	No dedicated procedure; payment incidents currently follow the general incident process.	Payment-related operational incidents are not separately identified in the reporting workflow.	Include payment-related incidents explicitly in the reporting procedure.	Compliance Officer	Q1 2027
Pillar 3 — Digital operational resilience testing (Chapter IV, Art. 24–27)								
DR-17	Art. 24	Digital operational resilience testing programme, proportionate to size and risk profile, as part of the ICT risk framework.	Gap	A.8.29 security testing in development; yearly external penetration test.	Testing happens, but there is no documented testing programme covering systems supporting critical functions.	Define and approve a testing programme with scope, frequency and reporting.	CISO	Q1 2027
DR-18	Art. 25	Testing of ICT tools and systems: vulnerability assessments, scenario-based tests, penetration testing, at least yearly for critical systems.	Partial	Monthly vulnerability scans (A.8.8); SAST in the CI pipeline; yearly external penetration test.	Individual tests are performed, but they are not planned against critical functions or consolidated into test reports for supervisory review.	Map the test plan to critical functions and consolidate results into a yearly report.	Head of Engineering	Q1 2027
DR-19	Art. 26, 27	Advanced testing based on threat-led penetration testing (TLPT), for entities identified by the competent authority.	Not applicable	Not applicable at the current size and risk profile: TLPT applies to entities identified by the competent authority.	Not applicable — recorded because the status can change as the company grows.	Re-assess applicability yearly, or if the entity is designated by the FMA.	Compliance Officer	Yearly review
Pillar 4 — Management of ICT third-party risk (Chapter V, Art. 28–44)								
DR-20	Art. 28	ICT third-party risk managed as part of the ICT risk framework, with a strategy and a designated responsibility.	Partial	A.5.19–A.5.22; supplier list with risk rating (partial); security clauses in main contracts.	Supplier management exists but is not structured as an ICT third-party risk strategy integrated into the framework.	Define the ICT third-party risk strategy and assign responsibility for monitoring arrangements.	Compliance Officer	Q1 2027
DR-21	Art. 28(3)	Register of information on all contractual arrangements with ICT third-party providers, maintained and reported to the authority.	Gap	Supplier list exists internally; no register in the regulatory format.	No register of information in the format required for submission to the competent authority.	Build the register of information following the applicable implementing standard.	Compliance Officer	Q4 2026
DR-22	Art. 28(8)	Exit strategies for ICT services supporting critical or important functions.	Gap	A.5.23 cloud exit planning mentioned in the Cloud Services Policy.	No documented exit strategy for the cloud services supporting the payment platform.	Document exit strategies for ICT services supporting critical functions.	CTO	Q1 2027
DR-23	Art. 29	Preliminary assessment of ICT concentration risk before entering into contractual arrangements.	Gap	Not addressed: supplier assessment is per-supplier, not portfolio-level.	Dependency on a small number of providers (Microsoft for both collaboration and infrastructure) is not formally assessed.	Assess ICT concentration risk and document the conclusion in the supplier procedure.	Compliance Officer	Q1 2027
DR-24	Art. 30	Contractual arrangements include the provisions required by the regulation (access, audit, termination, subcontracting, service levels).	Partial	A.5.20 contract template with security, audit and breach notification clauses.	Existing clauses cover security and audit, but not the full set of provisions the regulation requires for critical functions.	Update contract templates and renegotiate contracts for services supporting critical functions.	Compliance Officer	Q1 2027
Pillar 5 — Information-sharing arrangements (Chapter VI, Art. 45)								

#	Article	Requirement	Status	Supporting evidence (ISMS)	Gap	Action	Owner	Target
DR-25	Art. 45	Voluntary exchange of cyber threat information and intelligence within trusted communities.	Partial	A.5.6 contact with special interest groups (partial); A.5.7 ad-hoc threat monitoring.	Participation is informal; no arrangement with a trusted community is documented.	Join a sector community (for example CERT.at or a financial-sector group) and document participation.	CISO	Q3 2026

Status:

Compliant

Partial

Gap

Not applicable

Applicability: DORA applies since 17 January 2025. VindobonaPay is an authorised payment institution and not a microenterprise (Art. 3(60)), so the full regime of Articles 5–15 applies rather than the simplified framework of Article 16.

DORA is completed by regulatory and implementing technical standards that specify incident classification thresholds, reporting templates and the format of the register of information. This mapping stays at the level of the Regulation.

Source: EUR-Lex, Regulation (EU) 2022/2554. No regulatory text is reproduced: articles are referenced by number and described in my own words.

Priority actions — highest regulatory exposure first

Gaps ordered by supervisory visibility and dependency: reporting capability first, then third-party obligations, then testing.

Priority	Action	Requirements	Articles	Why it comes first	Owner	Target
1	Regulatory incident reporting procedure	DR-14, DR-15, DR-16	Art. 18, 19, 23	Without classification and reporting, a major incident would be handled internally but not notified within the deadlines. This is the most visible failure in a supervisory review.	Compliance Officer	Q1 2027
2	Register of information on ICT arrangements	DR-21	Art. 28(3)	The register is reported to the competent authority in a defined format; its absence is immediately verifiable.	Compliance Officer	Q4 2026
3	ICT third-party risk strategy, contracts and exit strategies	DR-20, DR-22, DR-23, DR-24	Art. 28, 29, 30	Contract renegotiation takes time and depends on providers, so it must start early even though the deadline is later.	Compliance Officer	Q1 2027
4	Digital operational resilience testing programme	DR-17, DR-18	Art. 24, 25	Testing already happens; what is missing is the programme that ties tests to critical functions and produces evidence.	CISO	Q1 2027
5	Internal audit of the ICT risk framework	DR-03	Art. 6(6)	Required for non-microenterprises and a prerequisite for demonstrating that the framework is reviewed independently.	Management	Q1 2027
6	Crisis communication plan	DR-12	Art. 14	Needed for responsible disclosure to clients and counterparts during a major incident.	COO	Q1 2027
7	ICT risk framework and resilience strategy documentation	DR-02, DR-06	Art. 6, 8	The substance exists in the ISMS; the work is presenting it in DORA terms and identifying critical functions.	CISO	Q1 2027

DORA Compliance Mapping — Summary

Values calculated automatically from the mapping sheet.

Requirements assessed	25
-----------------------	----

BY STATUS

Compliant	5
Partial	10
Gap	9
Not applicable	1

BY PILLAR

Pillar	Reqs	Open
1 — ICT risk management	12	8
2 — Incident management & reporting	4	3
3 — Resilience testing	3	2
4 — ICT third-party risk	5	5
5 — Information sharing	1	1

Pillar 1 is largely supported by the existing ISMS. The open work concentrates in Pillars 2, 3 and 4 — the same areas identified as 'Beyond ISMS' in Deliverable 03 and as gaps in Deliverable 04.